MIDNIGHT WEBS · FREE RESOURCE

Listă de verificare pentru securitatea lansării site-ului

Folosește această listă înainte de a conecta un site nou la domeniu. Acoperă accesul, HTTPS, backup-urile și elementele de bază care previn cele mai frecvente probleme.

ACTUALIZAT ÎN NOIEMBRIE 2026 · 12 MIN DE CITIT · MIDNIGHTWEBS.COM

1. Conturi şi acces

Majoritatea compromiterilor încep cu parole slabe sau refolosite, nu cu atacuri sofisticate. Rezolvă elementele de bază înainte de lansare.

- [ ] Folosește o parolă unică pentru fiecare cont de administrator; păstreaz-o într-un manager de parole.
- [ ] Activează autentificarea în doi pași pentru găzduire, registrarul de domenii, panoul CMS/admin și emailul de business.
- [ ] Șterge conturile vechi de administrator și accesul persoanelor care nu mai au nevoie de el.
- [ ] Oferă fiecărei persoane propriul cont; nu partaja datele de autentificare.
- [ ] Folosește cel mai mic nivel de permisiuni care îi permite fiecărei persoane să își facă treaba.
- [ ] Păstrează o evidență sigură a proprietarilor fiecărui cont și a modului de recuperare.

2. Domeniu, DNS şi HTTPS

Domeniul și DNS-ul controlează încrederea. O înregistrare configurată greșit poate redirecționa vizitatorii sau permite altora să trimită email în numele brandului tău.

- [ ] Activează blocarea registrarului și autentificarea în doi pași pentru contul de domeniu.
- [ ] Confirmă că certificatul SSL este valid, acoperă domeniul corect și se reînnoiește automat.
- [ ] Redirecționează HTTP către HTTPS și testează fiecare pagină.
- [ ] Adaugă înregistrările SPF, DKIM și DMARC pentru emailul de business.
- [ ] Șterge înregistrările DNS și subdomeniile nefolosite.
- [ ] Activează HSTS doar după ce HTTPS funcționează pe fiecare subdomeniu.

3. Platformă şi software

Fiecare plugin vechi este o altă cale de acces. Menține platforma actualizată și elimină ce nu folosești.

- [ ] Actualizează CMS-ul, pluginurile, temele și pachetele de server înainte de lansare.

- [ ] Șterge pluginurile, temele și extensiile pe care nu le folosești.
- [ ] Elimină conținutul demonstrativ, utilizatorii demo și numele de administrator implicite.
- [ ] Dezactivează listarea directoarelor și editarea fișierelor din panoul de administrare, dacă este posibil.
- [ ] Setează permisiuni sigure pentru fișiere și ține secretele în afara fișierelor publice.
- [ ] Folosește un firewall pentru aplicații web sau reguli de securitate dacă furnizorul de găzduire le oferă.

4. Formulare, plăţi şi date

Formularele și checkout-ul sunt părțile site-ului care primesc date necunoscute. Tratează fiecare câmp ca fiind ostil până când a fost validat.

- [ ] Adaugă CAPTCHA sau limitare a cererilor pentru formularele publice.
- [ ] Validează și curăță fiecare câmp pe server, nu doar în browser.
- [ ] Folosește protecție CSRF pentru acțiunile disponibile după autentificare.
- [ ] Colectează doar datele de care ai nevoie și explică de ce le colectezi.
- [ ] Stochează trimiterile formularelor într-un sistem protejat, nu în email simplu dacă includ date sensibile.
- [ ] Folosește câmpuri de plată găzduite, astfel încât datele cardului să nu ajungă pe serverul tău.

5. Backup şi recuperare

Un backup pe care nu l-ai restaurat niciodată este doar o speranță. Testează recuperarea înainte de a avea nevoie de ea.

- [ ] Activează backup-urile automate zilnice.
- [ ] Păstrează cel puțin un backup în afara contului de găzduire.
- [ ] Criptează backup-urile care conțin date personale.
- [ ] Testează o restaurare înainte de lansare, nu în timpul unui incident.
- [ ] Notează cine poate restaura, unde sunt backup-urile și cât durează recuperarea.

6. Monitorizare şi reacţie

Nu poți repara ce nu vezi. Asigură-te că cineva urmărește semnalele importante.

- [ ] Activează monitorizarea uptime-ului, a malware-ului și a modificărilor de fișiere.
- [ ] Trimite alertele de securitate către o căsuță monitorizată, nu către o adresă pe care nu o verifică nimeni.
- [ ] Configurează jurnalizarea erorilor și verifică-le după lansare.

- [ ] Păstrează un plan scurt de incident: pe cine suni, cum scoți site-ul offline și cum contactezi clienții.
- [ ] Știi cum să revoci rapid accesul dacă un dispozitiv sau un cont este pierdut.

7. Confidenţialitate şi aspecte legale

Securitatea și confidențialitatea se suprapun. Nu colecta date pe care nu le poți proteja sau explica.

- [ ] Publică o politică de confidențialitate care corespunde datelor colectate.
- [ ] Adaugă consimțământ pentru cookie-uri dacă folosești analytics, reclame sau cookie-uri neesențiale.
- [ ] Verifică faptul că formularele, newsletterele și checkout-ul trimit către politicile corecte.
- [ ] Șterge comenzile de test, utilizatorii de test și datele personale înainte de lansare.
- [ ] Asigură-te că datele de contact și de firmă sunt corecte.

8. Verificări în ziua lansării

Verificarea finală confirmă că site-ul funcționează în lumea reală, pe dispozitive reale și cu date reale.

- [ ] Testează fiecare formular și confirmă că trimiterile ajung.
- [ ] Testează checkout-ul, confirmarea plății și fluxul de rambursare dacă vinzi online.
- [ ] Verifică paginile 404, redirecționările și linkurile rupte.
- [ ] Elimină directiva noindex și confirmă că site-ul poate fi indexat.
- [ ] Trimite sitemap-ul în Google Search Console și Bing Webmaster Tools.
- [ ] Testează pe telefon, pe o conexiune lentă și într-o fereastră privată.
- [ ] Fă un backup final și notează ora lansării.

> **Repede de câștigat:** începe cu secțiunile despre conturi și backup-uri. Te protejează chiar dacă trebuie să amâni lansarea cu o zi.